VELOOP REWARDS - Privacy and Governance Proposal

Data Analyst Internship, Task 01 | Work Package P

Authenticity notice: Everything here is **Proposed** or **To Be Verified**. This work does not describe, test or reverse-engineer VELOOP's actual security controls and contains no credentials. Legal points are outlines that need Legal review. No simulated or real VELOOP statistics appear here.

1. Summary

- **A basic access model** for 6 roles (the brief's five plus Finance / Management) across 10 zones, with aggregated-only access for wider audiences and approved or sanitised datasets for interns.
- **All 128 dictionary fields are classified:** 3 Public, 119 Internal, 6 Restricted (money amounts, withdrawal methods and payout references). No personal-data fields exist.
- **The brief's list of information that must not be exposed** (passwords, authentication secrets, API keys, payment credentials, private credentials, sensitive security controls) is covered, with what to do if one is found.
- **Governance:** a proposed data owner and steward for each of the 10 entities, an access request workflow, and an intern dataset checklist.
- **Open legal questions are listed, not answered.** Retention, deletion and consent depend on where users are and need Legal input (A016).

2. Privacy principles

- Data minimisation: collect only what a defined KPI, event or check needs. The dictionary has no personal-data fields.
- Purpose limitation: each field lists its analytical use; data is not reused for unrelated purposes without approval.
- Pseudonymous identifiers: analysis uses user_id, never names or contact details.
- Least privilege: each role gets the lowest access that lets it do its work, for as long as it needs it.
- Aggregate by default: wider audiences see aggregated reporting; row-level access is the exception.
- Small-group protection: segments too small to hide an individual are suppressed in reports (the size threshold is to be agreed, not invented here).
- Separation: simulated data, test data and production data stay apart.
- Accountability: every dataset has an owner, every access grant is logged, and every definition change is recorded.

3. Roles

Role	What the Role Does With Data	Typical Access	Limits
Engineering	Implements events, collection, storage and the pipeline	Technical implementation access to collection, raw zone, reference data and pipeline health	Sees Restricted fields only where needed to build or debug; no routine exports
Data Analyst	Builds and maintains the analytics layer, quality rules and dashboards	Approved analytical datasets: raw (read), clean, analytics and reporting; quarantine triage	Restricted fields limited to named analysts working on wallet and withdrawals
Product / Operations	Uses reporting to make product and operational decisions	Aggregated business reporting and dashboards	No row-level data; small-group suppression applies
Finance / Management (added)	Reviews rewards, wallet and withdrawal totals and trends	Aggregated reporting including aggregated amounts	No row-level data; amounts only per unit
Content Team	Plans help, task and mission content	Aggregated content performance data where required	No user-level data
Intern	Works on analysis, specifications and test datasets	Only approved or sanitised datasets, including simulated data	No production row-level data, no Restricted fields, no credentials

4. Access matrix

Full = technical or build access. Read = row-level read. Aggregated = summarised data only. Approved datasets = only sanitised or simulated data that has passed the intern checklist. Approve = signs off changes. A dash means no access.

Zone	Engineering	Data Analyst	Product / Operations	Finance / Management	Content Team	Intern
Operational database	-	Not managed here (extract only)	-	-	-	-
Raw zone	Full	Read	-	-	-	-
Quarantine	Full	Read and resolve	-	-	-	-
Clean zone	Read	Read	-	-	-	-
Analytics layer	Read	Full (build)	Aggregated	Aggregated	Aggregated (content metrics)	Approved datasets
Reporting / dashboards	Read	Full (build)	Aggregated	Aggregated	Aggregated (content metrics)	Approved datasets
Simulated zone	Read	Full	Aggregated	-	-	Approved datasets
Reference data (lists, catalogue, dictionary)	Write	Write	Approve	Read	Read	Read
Pipeline health view	Full	Full	Read	Read	-	-
Documentation and specifications	Read	Read	Read	Read	Read	Read

5. Access by sensitivity

Role	Public	Internal	Restricted
Engineering	Read	Read	Only where needed to implement or debug; no routine export
Data Analyst	Read	Read	Named analysts only, for wallet and withdrawal work
Product / Operations	Read	Aggregated	Aggregated only
Finance / Management	Read	Aggregated	Aggregated amounts per unit only
Content Team	Read	Aggregated content metrics only	No access
Intern	Read	Sanitised or simulated only	No access

Fields by sensitivity

Entity	Public	Internal	Restricted
Users	0	21	0
Account_Status_History	0	7	0
Tasks	3	5	0
Task_Activity	0	17	0
Rewards	0	14	0
Wallet_Transactions	0	13	2
Withdrawals	0	11	4
Referrals	0	13	0
Feature_Events	0	12	0
Support_Tickets	0	6	0

Restricted fields: Wallet_Transactions.amount, Wallet_Transactions.balance_after, Withdrawals.requested_amount, Withdrawals.method, Withdrawals.completed_amount, Withdrawals.payout_provider_reference_id.

6. Information that must not be exposed

Information	Why It Must Not Be Exposed	Where It May Legitimately Exist	Rule for Analytics and Documents	If Found
Passwords	Gives account access	The authentication system only	Never collected, stored, logged or written into any document or dataset	Do not copy or share; tell Engineering; remove through quarantine
Authentication secrets (tokens, session secrets)	Allow impersonation	The authentication system only	Never in events, payloads or datasets	Same; Engineering rotates the secret
API keys	Allow use of VELOOP or partner systems	A secrets store managed by Engineering	Never in code samples, specs, spreadsheets or datasets	Same; Engineering revokes and reissues the key
Payment credentials	Financial harm	The payment or payout provider	Never collected; only a provider reference id may appear	Same; report immediately
Private credentials (database logins, service accounts)	Allow access to data and systems	A secrets store managed by Engineering	Never shared by message or stored in analyst tools	Same; Engineering rotates
Sensitive security controls (fraud thresholds, detection rules, bypass details)	Would help someone avoid controls	Security and Operations only	This work does not invent, reverse-engineer or document them; reason categories only	Do not use or share; tell the owner
Personal identifiers (name, email, phone, date of birth, identity documents)	Identify a person	Where the product legitimately needs them, not in analytics	Excluded from the data dictionary and events (Work Package B)	Quarantine and report
Precise location and raw IP address	Locate a person	Product or security logs, if any	Country code only; raw IP not carried into analytics	Quarantine and report
Payout account details	Financial harm and identification	The payout provider	Only provider reference ids; Restricted	Quarantine and report
Free-text support messages and reviewer notes	May contain personal data	The support system	Category fields only	Strip free text before use

7. Governance

Data owners and stewards (proposed)

Entity	Data Owner (accountable for meaning and access approval)	Data Steward (day-to-day quality)	Sensitivity Focus	Status
Users	Product	Engineering	Internal	Proposed
Account_Status_History	Operations	Engineering	Internal	Proposed
Tasks	Product	Content Team	Public / Internal	Proposed
Task_Activity	Product	Data Analyst	Internal	Proposed
Rewards	Finance	Data Analyst	Internal	Proposed
Wallet_Transactions	Finance	Engineering	Restricted amounts	Proposed
Withdrawals	Operations	Data Analyst	Restricted amounts and methods	Proposed
Referrals	Product	Data Analyst	Internal	Proposed
Feature_Events	Engineering	Data Analyst	Internal	Proposed
Support_Tickets	Operations	Data Analyst	Internal	To Be Verified

Access request workflow

Step	Action	Who	Notes
1	Request: who needs what data, for what purpose, for how long	Requester	Written; names the dataset, not just 'access'
2	Check need and sensitivity against the access matrix	Data Analyst	Reject if the need can be met with aggregated data
3	Approve	Data owner; Restricted data also needs the Product lead	Approval recorded
4	Grant least privilege, time-boxed	Engineering	Separate named credentials; no shared accounts
5	Log the grant and the dataset provided	Data Analyst	Access log kept
6	Review access periodically (cadence to be agreed)	Data owner	Remove unused access
7	Revoke on role change, project end or internship end	Engineering	Includes returning copies of exports

8. Intern dataset checklist

#	Check Before a Dataset Goes to an Intern	Done by
1	The dataset is simulated or sanitised, and says so in its label and generation notes	Data Analyst
2	No personal information (names, contacts, date of birth, location, raw IP)	Data Analyst
3	IDs are pseudonymous and any mapping key stays with Engineering	Engineering
4	Restricted fields (amounts, methods, payout references) are removed or aggregated unless specifically approved	Data Analyst
5	A scan finds no passwords, keys, tokens or credentials	Engineering
6	No segment is small enough to identify an individual (threshold to be agreed)	Data Analyst
7	Access is time-boxed and logged, and ends with the assignment	Data Analyst
8	Outputs are reviewed before leaving the team, so no production row-level data is included	Data Analyst

9. Basic security practices (proposed)

- Separate named accounts per person; no shared logins.
- Credentials and keys live in a secrets store, never in code, spreadsheets, chats or documents.
- Encryption in transit and at rest where the chosen tools support it.
- Access to the raw and Restricted zones is logged and reviewed.
- Backups follow the same access rules as the data.
- Exports leave the analytics environment only with approval and are tracked.
- These are proposed basics. This work does not describe, test or reverse-engineer VELOOP's actual security controls.

10. Retention, rights and incidents (outlines for Legal review)

Topic	Proposed Approach (outline)	Needs	Status
Retention of raw data	Define a retention period per zone; delete or anonymise after it	Legal and Product input; applicable rules depend on user geography (A016)	To Be Verified
User closure or deletion requests	Use user_id to find a user's records; because the raw zone is append-only, handle requests by anonymising records through a controlled process rather than editing history	Legal advice and an engineering design	To Be Verified
User access requests	Provide a user's own data through a defined process using user_id	Legal and Product input	To Be Verified
Notice and consent	Make sure what is collected matches what users are told	Legal and Product review of events and fields	To Be Verified
Cross-border storage and access	Record where data is stored and who can access it from where	Hosting decision (A011) and Legal	To Be Verified
Incident response	If personal data or a secret is found where it should not be, stop, contain, notify the owner and record it	Security and Legal procedure	To Be Verified

11. Open questions

- Which privacy rules apply, given where VELOOP's users are? This needs Legal input (A016).
- Which roles exist in practice and who is the named owner for each entity?
- What small-group size should trigger suppression?
- What retention periods apply to each zone?
- How often should access be reviewed?
- Which BI option will support aggregated-only access?

Next: Work Package Q - Analytics Change Management (the Metric / Event Change Log).